



**UNIVERSIDAD TECNOLÓGICA
DE QUERÉTARO**

Alumna:

Vasquez Noyola Andrea

Grupo:

IDGS17

Matrícula:

2023148002

Materia:

Seguridad en el Desarrollo de Aplicaciones

Práctica 2 - Parte 1

En este reporte se analizarán los errores comunes en procesos de autenticación, incluyendo credenciales predeterminadas, validación insegura y consultas vulnerables.

Durante la ejecución de pruebas controladas, se identificaron las siguientes vulnerabilidades críticas en el proceso de inicio de sesión:

El inicio de sesión como administrador se llevó a cabo con éxito ya que las credenciales de admin están escritas directamente en el código en el archivo de AuthController.

Al probar una entrada manipulada en el formulario, fue posible eludir completamente el sistema de inicio de sesión. La vulnerabilidad está en el código donde tenemos: `var user = _db.Users.FromSqlRaw(query).FirstOrDefault();` y, como ya se vio en la práctica 2-B, la entrada de `' OR '1'='1` devuelve toda la lista usuarios pero solo toma el primer usuario de la lista, es por eso que se ve la información del admin, ya que este usuario es el primero de la lista.

Recomendaciones de Seguridad

Para mitigar estos riesgos e implementar un proceso de autenticación seguro, se recomienda:

1. **Eliminar credenciales directamente en el código:** Remover cualquier bloque de código (como la validación `if (username == "admin"...)`) que evalúe credenciales quemadas en el código fuente. Toda autenticación debe realizarse contra los registros de la base de datos.
2. **Parametrizar consultas SQL:** Sustituir la concatenación de cadenas por consultas parametrizadas o, preferentemente, utilizar directamente los métodos integrados de Entity Framework (como LINQ) para buscar al usuario de forma segura, evitando así la inyección de código.
3. **Implementar Hash de contraseñas:** Aplicar un algoritmo de hashing fuerte (como BCrypt) antes de almacenar las contraseñas en la base de datos. Al iniciar sesión, se debe hashear la contraseña ingresada y comparar los hashes, nunca los textos planos.

Tabla de resultados de prueba

Prueba Realizada	Datos Ingresados	Comportamiento Esperado	Estatus y resultado Obtenido

1. Credenciales admin/admin	Usuario: admin Contraseña: admin	Acceso exitoso por validación en código (hardcoded).	Vulnerable: El sistema otorgó acceso inmediato al Dashboard mostrando los datos del administrador sin consultar la base de datos.
2. Credenciales válidas de usuarios semilla	Usuario: user1 Contraseña: 123456	Acceso exitoso consultando la tabla Users en la base de datos.	Exitoso: El sistema verificó los datos en la tabla y otorgó acceso al Dashboard mostrando la información correcta de user1.
3. Credenciales inválidas	Usuario: user1 Contraseña: 1dkam	Acceso denegado por credenciales incorrectas.	Exitoso: El sistema bloqueó el acceso, recargó la vista de Login y mostró el mensaje "Usuario/contraseña inválido".
4. Entrada manipulada	Usuario: ' OR '1'='1 Contraseña: ' OR '1'='1	Omisión de la seguridad explotando la inyección SQL del controlador.	Vulnerable: El sistema permitió el acceso al Dashboard sin necesidad de una contraseña real, iniciando sesión automáticamente con el primer registro de la tabla.